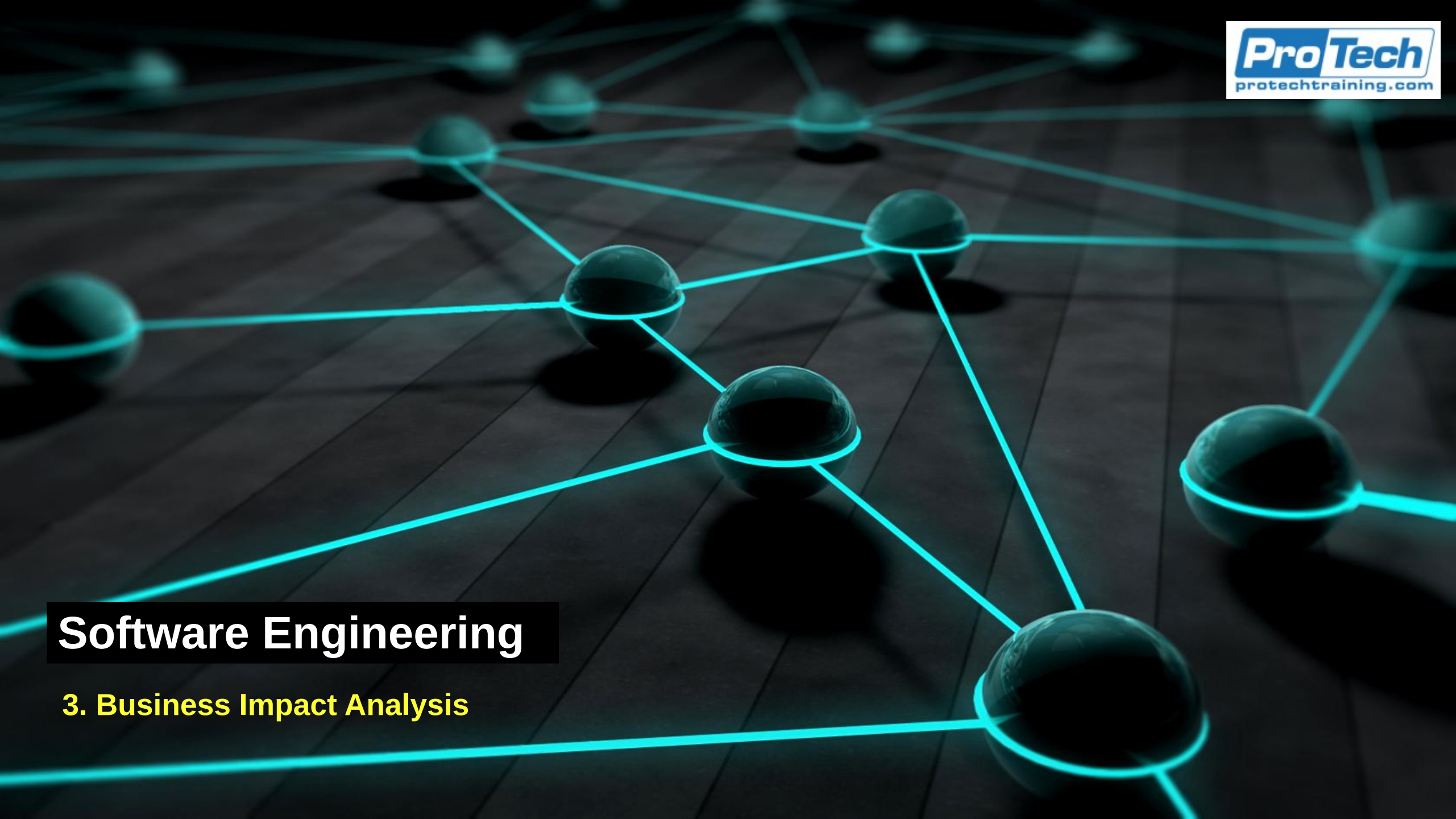




Software Engineering

3. Business Impact Analysis

Business Impact Analysis

In this module we will

- Define risk and resilience
- Introduce resilience measures for operations
- Introduce business impact analysis



Informal Definitions

- *Risk* and *resilience* are often used in an informal sense
- Risk is associated with the *probability* of an event happening
 - But with some implication of a negative consequence if that event occurs
 - “There is a risk of rain today, which means I might have to cancel our picnic”
 - “The operation has some risk to it; you might lose feeling in your leg”
 - Risk management requires a standardized and more precise definition
- Resilience implies that something is *tough*
 - Meaning that it can recover from negative events or attacks
 - “He is a resilient fighter, he took a lot of punches but managed to come back and win the fight”
 - “This material is so resilient that, no matter how you bend it, it snaps back to its original shape”
 - Like risk, a more precise formulation of “resilience” is needed

Rating Risk

- Risk events are evaluated along two dimensions
 - Events have a *probability* of occurring
 - “The chance of a hurricane making landfall in Boston MA this year is very unlikely”
 - “There is a good chance a hurricane will make landfall in Florida this year”
 - Events have *outcomes* that tells us the magnitude of the impact of the event
- Both dimensions can be quantitative or qualitative
 - “There is a 45% chance of a hurricane hitting Miami that would cause between \$400 million and \$800 million in property damage”
 - “There is a moderate chance of a hurricane hitting Miami that would cause high levels of property damage”
 - Qualitative measures are often good enough for informal risk evaluation
 - A primary goal of risk evaluation is to rank the severity of risks in order to prioritize which ones we should address first

Ranking Risk

- To prioritize risks
 - We have to “pick our targets”
 - We can’t do everything, so we have to ignore some risks to focus on others
 - The ones we ignore should be either very unlikely to occur or have a very minor impact
 - A typical assessment for risk occurrence is a set of ranked categories
 - *Certain*: it definitely will happen
 - *Likely*: the chance the event occurring is greater than it not occurring
 - *Possible*: even odds of the event occurring
 - *Unlikely*: the chance the event occurring is less than it not occurring
 - *Rare*: the chance of it happening is very low
 - *Eliminated*: the event cannot occur

Ranking Risk

- An assessment for outcomes is also a set of ranked categories, for example
 - *Catastrophic*: death or permanent total disability, significant irreversible environmental impact, total loss of equipment
 - *Critical*: accident level injury resulting in hospitalization, permanent partial disability, significant reversible environmental impact, damage to equipment
 - *Marginal*: injury causing lost workdays, reversible moderate environmental impact, minor accident damage level
 - *Minor*: injury not causing lost workdays, minimal environmental impact, damage less than a minor accident level
- If there is no negative outcome when the event occurs
 - Then there is no risk because the event has no impact on us
- Once there are rankings of the likelihood and outcome
 - We can classify the overall risk of the event
 - Usually taken as the informal product of the two rankings
- Often represented by a risk matrix

Risk Matrix

- Each risk can now be prioritized
- The *very high* risks are dealt with first
 - These events are certain or likely to happen and will have severe negative impacts
 - These generally need to be done urgently
- We may ignore the *low* risks
- We can prioritize management of the mid-range risks based on other criteria
 - For example, high costs of a *high* risk mitigation may mean deferring actions because we can't afford to do it
 - Or a *medium* risk may be deferred because the skill sets to mitigate it might not be available
- Establishes a way to triage risks

Likelihood	Harm severity			
	Minor	Marginal	Critical	Catastrophic
Certain	High	High	Very high	Very high
Likely	Medium	High	High	Very high
Possible	Low	Medium	High	Very high
Unlikely	Low	Medium	Medium	High
Rare	Low	Low	Medium	Medium
Eliminated	Eliminated			

Common Risk Matrices

- A risk matrix is a visual tool
 - There is no official format
 - On the right is a common 3x3 form
- The example is qualitative
 - Useful as a first analysis
 - Often uses historical data and expert opinions to come to a preliminary decision
 - This is called a qualitative analysis

3 x 3 Risk Matrix

L I K E L I H O O D	Likely	Medium Risk	High Risk	Extreme Risk
	Unlikely	Low Risk	Medium Risk	High Risk
	Highly Unlikely	Insignificant Risk	Low Risk	Medium Risk
		Slightly Harmful	Harmful	Extremely Harmful
CONSEQUENCES				

Common Risk Matrices

- Shown is a 5x5 matrix
- Incorporates a risk management decision to prioritize responses
- These examples show there is no “correct” form of a risk matrix
 - They all express the idea of computing risk as a combination of likelihood and outcome
 - The actual risks will depend on how we choose to define and classify them
 - Those choices are what we need to get right in a risk assessment

Likelihood	Unlikely (1)	Low risk. No further action	Low risk. No further action	Low risk. No further action	Low risk. No further action	Medium risk. Further action optional
	Seldom (2)	Low risk. No further action	Low risk. No further action	Medium risk. Further action optional	Medium risk. Further action optional	High risk. Further action necessary
	Occasional (3)	Low risk. No further action	Medium risk. Further action optional	Medium risk. Further action optional	High risk. Further action necessary	Extreme risk. Act now
	Likely (4)	Medium risk. Further action optional	Medium risk. Further action optional	High risk. Further action necessary	Extreme risk. Act now	Extreme risk. Act now
	Definite (5)	Medium risk. Further action optional	High risk. Further action necessary	Extreme risk. Act now	Extreme risk. Act now	Extreme risk. Act now
		Insignificant (A)	Marginal (B)	Moderate (C)	Critical (D)	Catastrophic (E)

Quantitative Risk Matrices

- Quantitative matrices use data to assign the frequency and outcome values
 - These values are usually derived from existing data
 - They can be based on some mathematical model; a regression analysis for example
- The model might incorporate:
 - Analyses of historical data to predict the likelihood of an event
 - *This could be expressed as a probability of the event occurring according to a statistical model*
 - A set of impacts on affected populations based on historical occurrences
 - *For example, historical records of the dollar value of damage for similar events*
 - Used for a more comprehensive description of the risk
 - The next page shows a quantified risk matrix from the liquid natural gas industry
- No matter how detailed or precise the risk matrix is
 - It doesn't tell us how to manage risk or reduce the risk
 - We need a standard set of concepts, procedures and strategies for responding to risk

LNG Risk Matrix Example

CONSEQUENCES							INCREASING PROBABILITY (Likelihood)→							
INCREASING SEVERITY ↓		Category						A	B	C	D	E		
		People	Asset / Production	Environment	Reputation	Community Relation	Security	Never heard of in the Oil & Gas Industry	Heard of in the Oil & Gas Industry	Has happened in the LNG Industry or more than once per year in the Oil & Gas Industry	Has happened at NLNG or once per year in the LNG Industry	Has happened more than once per year in NLNG		
	0	No injury or health effect	No damage	No effect	No impact	No impact	No impact	A0	B0	C0	D0	E0		NEGLIGIBLE
	1	Slight injury or health effect (FAC)	Slight damage (10k\$ & no disruption to operation)	Slight effect (within fence, no exceedance)	Slight impact (E.g. public awareness)	Incidental problem	Minimal impact resolved internally	A1	B1	C1	D1	E1		LOW
	2	Minor injury or health effect (MTC, RWC<= 5days, food poisoning & dermatitis)	Minor damage (10k\$ - 100k\$ & brief disruption)	Minor effect (Minor impact but no lasting effect)	Limited impact (E.g. local / public media)	Threats of bodily harm to personnel, without action; Re-instatement of no go areas	Low impact resolved with Company dedicated GSAs	A2	B2	C2	D2	E2		MEDIUM
	3	Major injury or health effect (LTI, RWC >5Days.)	Moderate damage (0.1 - 1.0M\$ & partial shutdown)	Moderate effect (Limited Env. Impact that requires clean up)	Considerable impact (E.g. region / state / public media)	Several days of blockade of local facilities, rivers, water pump station or gas supply station)	Medium impact resolved with support from Local GSAs	A3	B3	C3	D3	E3		HIGH
	4	Permanent Total Disability (PTD) or up to 3 fatalities	Major damage (1.0 - 10.0M\$ & partial operation loss)	Major effect (severe damage recoverable / extended exceedance)	Major Impact (E.g. extensive adverse media)	Severe damage to water supply or gas station reported in Nigerian media	Major impact resolved with support from State GSAs	A4	B4	C4	D4	E4		
5	More than 3 fatalities	Extensive damage (>10M\$ & substantial operation loss)	Massive effect (widespread chronic effects / constant high exceedance)	Massive impact (E.g. extensive adverse media)	Impossible to operate without major military support	Massive impact resolved with support from National GSAs	A5	B5	C5	D5	E5			

Alternative Terminology

- Our discussion so far
 - We have used the idea of risk *events* with a probability of *occurrence* with a potential *outcome*
- Another way of describing this:
 - There exist *threats* to the organization
 - *Threats are events, but the term threat emphasizes the negative nature of the event*
 - *A power outage is a threat, so is a hacker attack*
 - Threats are exploited through vulnerabilities
 - *A vulnerability represents a negative outcome*
 - *The more vulnerable we are correlates with higher negative impact of the threat*
 - *Mitigating the vulnerability reduces the effect of the threat*
 - For example
 - *An earthquake represents a threat to our data center since it can have a negative impact on our data center*
 - *Locating the data center near a fault line is a vulnerability because it increases our potential to take damage from the threat*

Resilience Concepts

- Resilience refers to how a system deals with negative events and returns to normal operations
- Resilience is not about avoiding negative events
 - We accept the fact that negative events will occur and will impact the system
 - A resilient system absorbs these events with no or only minimal loss
 - Resilience means the systems recovers from the event with minimal effects
 - *If the system goes down in whole or part, its function can be restored quickly*
- Related concepts
 - *Continuity*: refers to the idea a business, for example, can continue to function even when there is a failure in a system, although it might operate at a reduced capacity for a while
 - *Reliability*: refers to the idea that the resilience of the system ensures it is consistently available and operational

Resilience

- Basic themes in resilience operations
 - *Anticipate*: Identify the points of failure and dependencies where things could go wrong
 - *Withstand*: Keep operations running when parts fail
 - *Maintain continuity of operations, even at a degraded level*
 - *Recover*: Restore full operations quickly
 - *Recovery strategies, restore from backups, switch to redundant systems, and execute failover plans*
 - *Adapt*: Learn from incidents and improve
 - *Improves the reliability of the system*
- Like risk management, resilience needs
 - Standard concepts, procedures and protocols, including assessment tools
 - Constant improvement in the organization's resilience processes and procedures
 - To be integrated across systems and coordinated with other functional areas

Formal vs Informal Definitions

- Risk
 - Informal
 - *“Something bad might happen because...”*
 - *“It would be terrible if someone could break into our system with administrator privileges”*
 - Formal Definition
 - *A potential event/condition with likelihood and impact on objectives*
- Issue
 - Informal
 - *“Something bad could happen if we don’t fix this”*
 - *“The administrator account login has not been disabled for external logins over the Internet”*
 - Formal Definition
 - *A current problem (realized risk) requiring remediation*

Formal vs Informal Definitions

- Control
 - Informal
 - *“Unless we put this security feature into place, bad things will happen”*
 - *“We need to ensure administrators can only log in from inside our IT department network”*
 - Formal Definition
 - *A policy/process/technical measure to reduce likelihood/impact or detect/recover*
- Incident
 - Informal
 - *“That issue we didn’t address, it just caused a bad thing to happen”*
 - *“Someone hacked in as administrator and deleted the entire code base for our next release”*
 - Formal Definition
 - *A disruptive event affecting confidentiality, integrity, availability, or operations.*

Formal vs Informal Definitions

- Remediation
 - Informal
 - *“We need to deal with this security issue”*
 - *“We need to ensure administrators can only log in from inside our IT department network”*
 - Formal Definition
 - *Actions to resolve an issue or strengthen controls to reduce risk*
- Recovery
 - Informal
 - *“We dodged a bullet this time”*
 - *“We were able to restore the deleted code base from the last backup with minimal loss so we can continue development”*
 - Formal Definition
 - *Activities to restore services/data to an acceptable state and service level agreements*

Formal vs Informal Definitions

- Inherent risk
 - Informal:
 - *“All the risk we face before we do anything”*
 - *“Literally anyone can log into our system from anywhere as administrator and use a brute force attack to get full system access”*
 - Formal Definition
 - *The level of risk before considering existing controls*
- Residual risk
 - Informal
 - *“We fixed most of the problem, but there are still some issues”*
 - *“No one can get administrator access from outside, but we still have to worry about social engineering attacks on our existing staff to gain internal access”*
 - Formal Definition
 - *The level of risk after controls are applied*

Formal vs Informal Definitions

- Risk appetite
 - Informal:
 - *“We are willing to take these risks otherwise we may not be able to get something important done”*
 - *“Because we are committed to developing AI tools, we are willing to accept the risks inherent in new technology development”*
 - Formal Definition
 - *The amount of risk an organization is willing to accept in pursuit of its objectives*
- Risk tolerance
 - Informal:
 - *“How much risk we are willing to accept before we start to panic”*
 - *“No more than 2% of transactions per year may fail due to IT issues”*
 - Formal Definition
 - *The acceptable level of variation in outcomes related to specific risks, often expressed in measurable thresholds*

Risk Tolerance Example

- UNIX operating system and C programming language
 - Both have a reputation for being “risky”
 - Programmers can write C code on a UNIX system that would crash or brick the system
 - This requires a high risk tolerance
- Doug Gwyn explains why
 - *“Unix was not designed to stop you from doing stupid things, because that would also stop you from doing clever things”*
 - Risk management is the programmer’s responsibility, not the operating system’s responsibility



Resilience

- Differences between risk and reliability/resilience
 - Risk management focuses on preventing things from going wrong
 - Reliability focuses on maintaining normal operations when things go wrong
 - *For example, systems that reject bad data that has the potential to crash operations are reliable because they continue to function even when given corrupted input*
 - Resilience is about absorbing bad events and getting back to normal fast
 - *If bad data does crash the system, it reboots and is online with minimal downtime*
 - Resilience is about expecting failure, limiting the fallout, and returning to service predictably so customers and the business keep operating
 - Reliability tries to avoid failure
 - Resilience assumes failure will happen and focuses on recovery from the failure

Resilience

- Security vs. Resilience
 - Security reduces the likelihood of attacks by an adversary will succeed
 - Resilience reduces the impact and duration of the effects of an attack on the system
- Redundancy vs. Resilience
 - Redundancy is a tool (extra capacity, backups)
 - Resilience is the strategy that decides where and how to use redundancy tools
- Resilience (recall)
 - *Anticipate*: Spot what could go wrong (single points of failure, dependencies)
 - *Withstand*: Keep core services running when parts fail (graceful degradation)
 - *Recover*: Restore full service quickly (clear roles, practised runbooks, tested backups)
 - *Adapt*: Learn from incidents and improve so the same issue hurts less next time

Resilience

- Organizational resilience
 - *“Ability of an organization to absorb and adapt in a changing environment to deliver objectives and to survive and prosper”*
- RTO (recovery time objective)
 - How fast the organization must restore an activity/service to an acceptable level after a disruption
 - The amount of down time needed to be restore the system enough to continue operations normally
- RPO (recovery point objective)
 - How much data the organization can afford to lose
 - Expressed as a point in time that the process must be able to roll back to
 - *For example: “no more than 5 minutes of orders lost”*

Resilience

- MTPD (maximum tolerable period of disruption)
 - Beyond this duration, the impact on the business becomes unacceptable
 - Outer limit for a disruption before the the business suffers loss
 - RTO must always be set inside this boundary
 - Also called MAO Maximum Acceptable Outage
- MBCO (minimum business continuity objective)
 - The minimum acceptable performance level during disruption
 - *For example: “process 20% of payments during system recovery”*
 - The RTO is the time to reach at least the MBCO
- BIA (business impact analysis)
 - Analysis step that quantifies impact over time and helps calculate realistic RTO/RPO per activity/application

Banking Example

- Payments process routing:
 - MTPD: 2 hours
 - *Beyond that: regulatory, reputational impact is unacceptable*
 - RTO: 15 minutes to MBCO
 - *Time required to route 30% of traffic through secondary processor (MBCO)*
 - RPO: 1 minute
 - *Can't lose more than 1 minute of auth logs/transactions*
 - Resilience Planning:
 - *Synchronous replication for auth logs, hot-hot routing, automated failover playbook*

Banking Example

- Trade confirmations portal:
 - MTPD: 24 hours
 - RTO: 4 hours
 - *Read-only mode acceptable initially*
 - RPO: 15 minutes
 - *Replayable from upstream book of record*
 - Resilience Planning:
 - *Frequent backups + near-real-time replicas; runbook for read-only mode*

Business Impact Analysis

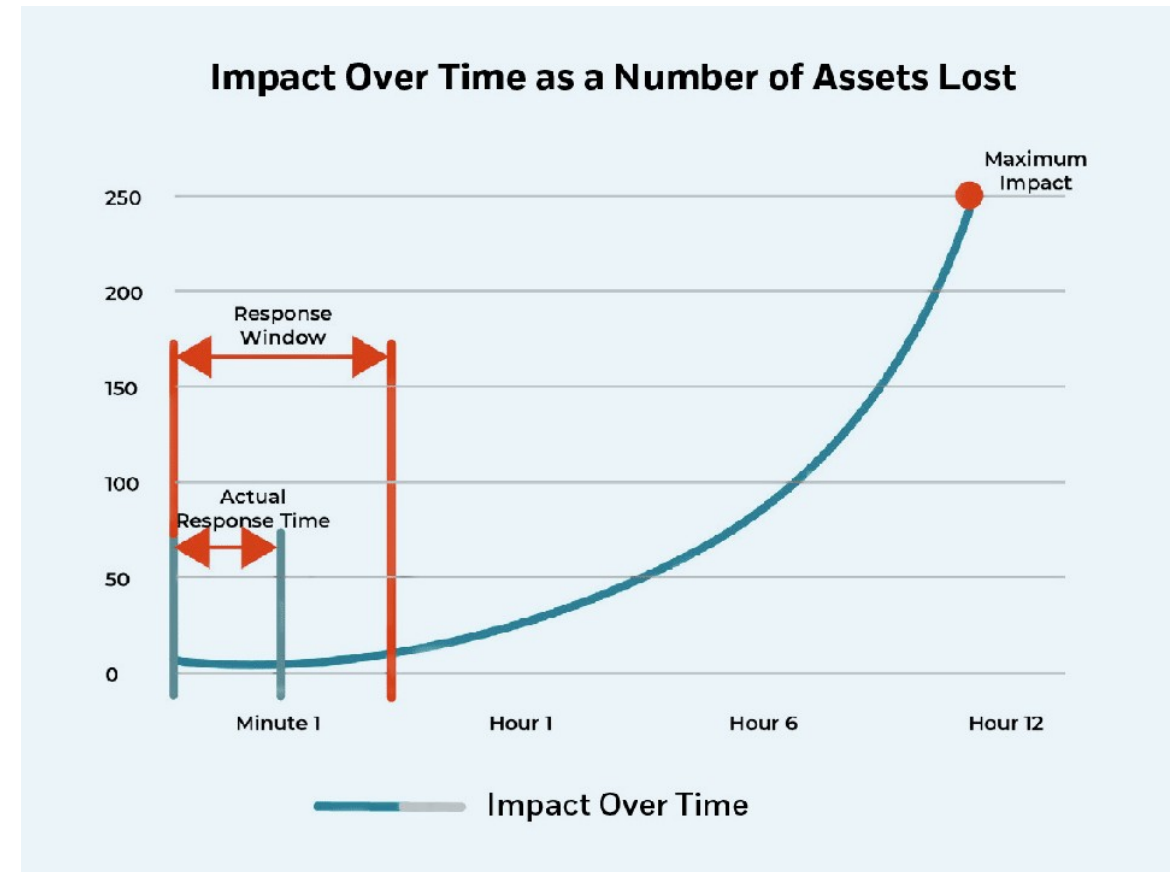
- Structured way to assess how bad things get over time when a business activity or IT service is disrupted
 - Quantifies the impacts on financial, customer, regulatory, operational dimensions
 - Used to set targets for resilience planning, specifically
 - *RTO: How fast the system must be back to a minimum level*
 - *RPO: How much data the business can afford to lose*
 - Identifies
 - *Which services matter most*
 - *How quickly the pain escalates*
 - *What recovery promises have to be kept*
 - Also useful for discovering risks

Business Impact Analysis

- BIA key outputs
 - Criticality tier for each related or dependant service or application
 - *An evaluation of how important each service is to maintaining business continuity*
 - *Tier 1 “mission critical,” Tier 2, etc.*
 - Impact curve over time
 - *Scale of tolerable service degradation to the severe service degradation that is unacceptable versus time*
 - *A measure of how the impact to the business gets worse over time*
 - MTPD/MAO for each activity
 - *Defines the outer limit for what is acceptable*
 - RTO and RPO targets
 - *Defines the targets are that are to be designed to and tested against*

Business Impact Analysis

- BIA key outputs
 - Criticality tier for each related or dependant service or application
 - *An evaluation of how important each service is to maintaining business continuity*
 - *Tier 1 “mission critical,” Tier 2, etc.*
 - Impact curve
 - *Scale tracking service degradation over time from tolerable service degradation to unacceptable*
 - *Measure of how the impact to the business gets worse over time*



Business Impact Analysis

- Minimum Business Continuity Objective (MBCO):
 - *The minimum acceptable service level during disruption*
 - *Although service might be degraded, defines minimum level of service to avoid business failure*
- Dependency map
 - *Identifies the people, locations, technology, data and third parties that are involved or impacted*
- Regulatory/contractual constraints
 - *Identifies the legal and compliance issues that have to be taken into account*
 - *Important because what the business can tolerate as MBCO might not be acceptable to regulators*
- Prioritized recovery order and data protection needs
 - *What needs to be done first*
 - *How to protect the data assets*
- Assumptions and residual risks
 - *Identifies what could still go wrong even after a recovery*
 - *For example, determining if an outage a planned diversion by someone hacking the system*

How to do a BIA

- Phase 1: Prepare (1–2 weeks)
 - Define scope: Which business activities are to be analyzed
 - Identify the underlying IT services that are involved
 - *Applications, databases, payment rails, call center, branches systems*
 - Pick impact criteria describing the impact of failure along various dimensions
 - *Financial (per hour/day)*
 - *Customer (volume affected, VIP segments)*
 - *Regulatory (reporting deadlines, penalties)*
 - *Operational (manual workarounds)*
 - *Reputation (media/social triggers)*
 - Use a quantified scale with concrete thresholds
 - *For example: “Regulatory breach likely” = level 4*

How to do a BIA

- Phase 1: Prepare (cont)
 - Collect reference data
 - *Past incidents, SLAs, volumes, cutoffs, market windows*
 - *For example : payment settlement times, control test results, known issues*
 - Example impact criteria for a bank
 - *Financial: revenue loss, fees/penalties, trading P&L, cost of manual work*
 - *Customer: number of customers unable to transact, VIP/segment impact, queue/abandon rates*
 - *Regulatory & Legal: reportable incidents, filing deadlines missed, consent order exposure, fines*
 - *Operational: throughput drop, backlog growth, staff hours for workaround, dependency breakage*
 - *Reputation: media/social escalation, complaints, net promoter score drop, executive attention*
 - *(Optional) Safety/People: rarely used in IT-only outages, but included if relevant (example, fire sensor software)*

How to do a BIA

- Phase 1: Prepare (cont)
 - Example: ranked impact criteria for a bank

Criterion	1 – Low	3 – Moderate	5 – Intolerable
Financial (per day)	<\$10k	\$250k–\$1M	>\$5M
Customer blocked	<100	5k–50k or VIPs impacted	>250k or nationwide
Regulatory	None	Filing delay/notice	Reportable breach or fine likely
Operational	Minor workaround	Sustained manual backlog	No viable workaround
Reputation	Internal noise	Social/media chatter	National coverage/Board-level

How to do a BIA

- Phase 2: Elicit and validate (2–4 weeks)
 - Interviews/workshops
 - *With business owners and tech leads (Dev/SRE/DBA/Network)*
 - Use the same questionnaire to ensure comparability
 - *What does the activity produce? Who depends on it?*
 - *What happens at 15m / 1h / 4h / 24h / 3d of downtime?*
 - *What data would be lost at different points? How hard is reconciliation or restoration?*
 - *What's the minimum acceptable level for business continuity (MBCO)?*
 - *Any hard deadlines: market close, clearing windows, regulatory submissions*
 - Map dependencies
 - *Applications, data stores, identity, networks, endpoints, facilities, vendors, SLAs*
 - Quantify impact over time
 - *Convert narratives into scores and impact curves*
 - *Identify the time when impact becomes unacceptable, that becomes the MTPD/MAO*

How to do a BIA

- Phase 3: Set targets and align (1–2 weeks)
 - Derive targets
 - *RTO = time to resume to at least the MBCO, and always < MTPD*
 - *RPO = max tolerable data loss window based on data volatility and reconciliation cost*
 - Prioritize recovery order
 - *If multiple services are down, identify the order in which they should be restarted*
 - Validate feasibility with IT:
 - *Can the current architecture meet RTO/RPO?*
 - *If not, document the gaps, options, and costs to make it compliant*

How to do a BIA

- Phase 4: Publish and embed (1 week)
 - Deliver the BIA register/report
 - *Criticality tiers, impact curves, targets, dependencies, assumptions*
 - Flow targets into plans and tests
 - *Update DR runbooks, exercise calendar, monitoring dashboards (RTO/RPO/MTPD)*
 - Set review cadence:
 - *Re-run or refresh annually or after major changes*
 - *For example: mergers, platform shifts, new regulations*

How to Determine RTO

- Scope the activity
 - Name the business service
 - *For example: card authorizations*
 - And the IT stack that supports it
 - *For example: apps, DBs, networks, vendors*
- Execute a BIA
 - Quantify impact as a function of outage time
 - *For example: financial, customer, regulatory, operational*
 - Identify the MTPD/MAO: the point at which impact becomes unacceptable
- Set a measurable target
 - Pick the $RTO < MTPD$ that reflects the minimum acceptable level of service (MBCO).
 - *Example: “15 minutes to read-only balances, 60 minutes to full function”*

How to Determine RTO

- Check external constraints
 - Regulatory rules, customer SLAs, market hours, and cutoffs like payment settlement windows that may force a tighter RTO

Design to the number

- Choose strategies that can actually meet the RTO
 - *For example, active-active, hot standby, autoscaling, automated failover, pre-provisioned capacity*
- Cost–risk tradeoff
 - Compare business benefit of a shorter RTO vs. added run costs and complexity
 - Adjust if the economics don't justify “minutes”
- Document and test
 - Put RTO in runbooks and DR plans
 - Validate with timed exercises; record actual recovery time and fix gaps

How to Determine RTO

- Understand the data that would be affected
 - For example: orders, trades, auth logs
 - How often they are updated, their rate of change
 - How they are reconciled if the data is lost
- Establish the tolerance
 - With business owners, set the largest acceptable loss window
 - For example: “ ≤ 5 minutes of orders lost”
- Map to data protection options
 - $RPO \approx 0$: synchronous replication, dual-write, commit-quorum
 - RPO in minutes: asynchronous replication + frequent log shipping/snapshots
 - RPO in hours: periodic backups are sufficient

How to Determine RTO

- Check downstream dependencies
 - If systems feed each other, the strictest RPO in the chain often dictates the RPO for all the other related systems
- Prove recoverability
 - Run point-in-time restores and message replays to show you can recover on before the specified RPO
 - Keep logs as evidence

Real World Issues

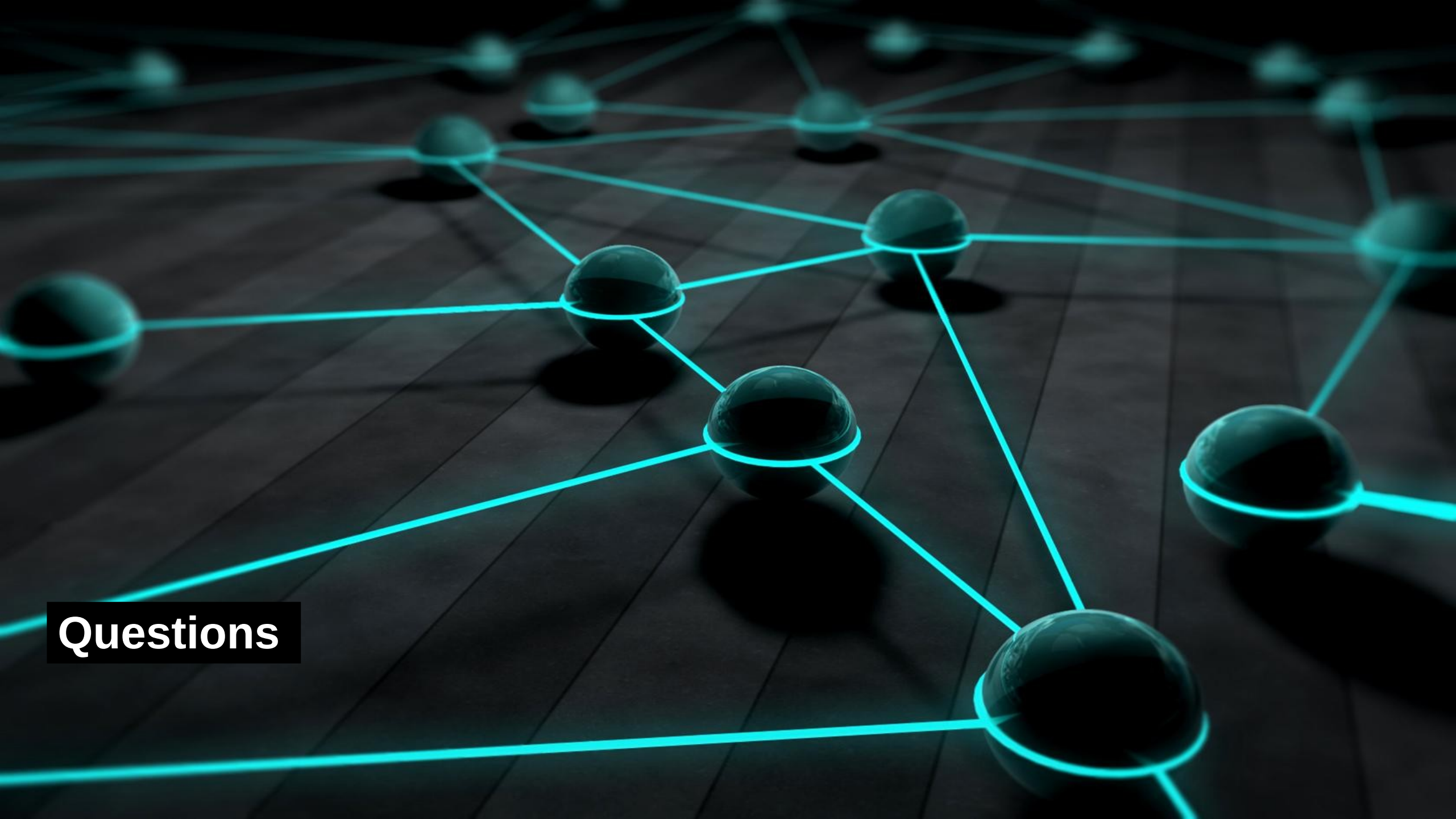
- Feasibility loop
 - If architecture can't meet the chosen RTO/RPO then either
 - Invest (hotter standby, faster replication) or
 - Revise targets with signed risk acceptance
- Tiers
 - Not every component needs the same target
 - Design graceful degradation
 - *For example, read-only mode meets RTO for one subsystem while other subsystems work on meeting their RTO*

Risk Contribution

- Implicit in the discussion of resilience
 - The assumption is that we understand the risks involved in outages of any type
 - Essential in doing a BIA
- In developing a BIA, it might be discovered that some failures cannot be recovered from
 - For example:
 - *A critical system is a legacy system which no one really understands anymore*
 - *The in house expertise to perform the recovery operations does not exist*
 - *The IT dependencies are so complex that a single failure might result in a cascading total failure of the entire IT infrastructure*

Risk Contribution

- This creates a risk profile that might not have been obvious before
- Risk management then has to assess the various types of risks discovered
 - Generally uses the following categories for discovered risk
 - *Operational risk: Risk of loss from inadequate or failed processes, people, and systems or from external events; includes legal risk, excludes strategic and reputational risk*
 - *Information security & privacy risk: Risk to organizational operations/assets and individuals from the operation and use of information systems (security and privacy)*
 - *Strategic risk: Risk to achieving strategy and business objectives (e.g., tech choices that hinder strategy execution)*
 - *Compliance risk: Risk of violations of existing laws/regulations or internal policy requirements*



Questions